

PCI DSS Scope Register

In-scope components, reduced-scope assets, third-party dependencies and cardholder-data flow narrative.

Document ID	PCI-V2-SR-002
Prepared by	Richmond Kwadwo Sarpong
Case study	Akwaaba Retail & Online Ltd. (fictional)
Date / version	20 August 2026 / Version 2.0

Independent fictional portfolio case study - not a Report on Compliance, Attestation of Compliance, QSA assessment, or evidence of work performed for a real merchant.

1. Scoping Principle

Scope includes any system that stores, processes or transmits account data, plus systems that secure, administer, connect to, or could affect the security of the CDE. Segmentation is treated as a scope-reduction control that must be validated and tested; separate VLANs alone do not establish effective segmentation.

2. In-Scope Component Register

ID	In-scope component	Scoping rationale	Owner
S-01	E-commerce checkout and payment-page code	Serves scripts and captures card data before direct transmission to the gateway	Merchant IT
S-02	CDN, WAF and load balancer	Protects and routes payment-page traffic; can affect CDE security	Merchant / TPSP
S-03	Payment API integration and secrets vault	Authenticates payment calls and receives tokens and authorization results	Merchant IT
S-04	Order database	Stores gateway token, authorization reference, card brand and last four digits	Merchant IT
S-05	POS terminals and payment VLANs	Capture card data and transmit encrypted transactions to the acquirer	Retail Operations
S-06	Firewalls, VPN, bastion and admin endpoints	Control and administer access to CDE components	Infrastructure
S-07	Central logging / SIEM	Receives security events from CDE components and supports detection	Security
S-08	Source repository and CI/CD pipeline	Can change payment-page code and scripts	Engineering
S-09	Settlement reporting	Receives masked PAN and payment summaries	Finance

3. Out-of-Scope or Reduced-Scope Assets

- HR and payroll systems with no CDE connectivity or account data, subject to validated segmentation.
- Corporate email and general office productivity systems, except privileged endpoints used to administer the CDE.
- Customer relationship management records containing only gateway tokens and masked PAN, subject to verification that tokens are irreversible outside the gateway environment.
- A separate marketing website that does not host or influence checkout content, subject to configuration and dependency validation.

4. Third-Party Service Dependencies

Provider	Service	Required assurance
Payment gateway / acquirer	Authorization, tokenization and settlement	Current PCI DSS AOC; service description; responsibility matrix
Cloud hosting provider	Compute, storage, network and physical infrastructure	AOC; shared-responsibility model; service configuration evidence
CDN / WAF provider	Edge protection and payment traffic routing	AOC or relevant assurance; configuration export; change records
Approved Scanning Vendor	External vulnerability scans	Passing ASV reports and remediation evidence

5. Cardholder-Data Flow Narrative

- 1. Online payment: the customer loads checkout through the CDN/WAF; the merchant payment page transmits PAN to the compliant gateway over strong cryptography.
- 2. The gateway returns only a payment token, masked details and an authorization result to the merchant application and order database.
- 3. In-store payment: a P2PE terminal encrypts card data at capture and routes it through the restricted payment network to the gateway/acquirer.
- 4. Administrators use individually assigned accounts, MFA, VPN and a bastion to manage CDE systems; security events are centralized in the SIEM.
- 5. Finance and customer service use masked settlement data and tokens only; access remains role-based and logged.

6. Scope Validation Checklist

Validation activity	Expected result
Reconcile system inventory to network and data-flow diagrams	All CDE, connected-to and security-impacting components are accounted for.
Validate segmentation controls	Connectivity testing and segmentation testing support scope reduction.
Review third-party responsibility	Current assurance and responsibility matrices cover each service.
Review data discovery results	No unexpected PAN or sensitive authentication data is retained.
Review change impact	Significant changes trigger scope and diagram updates.

Acronyms and Definitions

Document-specific reference glossary for **Scope Register**. Definitions are written in plain language for recruiters, reviewers and non-specialist readers.

Acronym	Full meaning and explanation
AOC	Attestation of Compliance A formal declaration that applicable PCI DSS requirements have been assessed.
CDE	Cardholder Data Environment The people, processes and technologies that store, process or transmit cardholder data, or can affect its security.
CHD	Cardholder Data At minimum, the primary account number; it may also include the cardholder name, expiration date or service code.
DMZ	Demilitarized Zone A segmented network area that separates externally accessible services from internal systems.
P2PE	Point-to-Point Encryption A PCI-validated solution that encrypts payment data from the point of interaction to the secure decryption environment.
PAN	Primary Account Number The payment card number that identifies the issuer and cardholder account.
PCI DSS	Payment Card Industry Data Security Standard The global security standard for protecting payment account data.
POS	Point of Sale The system or device used to accept and process customer payments.
QSA	Qualified Security Assessor A PCI SSC-qualified organization or individual that performs PCI DSS assessments.
ROC	Report on Compliance A detailed report documenting the results of a PCI DSS assessment.
SAD	Sensitive Authentication Data Security-related data used to authenticate cardholders or authorize transactions; storage is restricted after authorization.
SAQ	Self-Assessment Questionnaire A validation tool for eligible entities to document PCI DSS self-assessment results.
TPSP	Third-Party Service Provider An external provider whose services store, process, transmit or can affect the security of account data.
VLAN	Virtual Local Area Network A logical network segment used to separate systems and traffic.

Portfolio note: This glossary supports a fictional PCI DSS v4.0.1 readiness case study and does not represent a formal compliance determination.